1. System Requirements

1.1 Functional Requirements

User & Identity

- Self-registration via MSISDN + OTP
- NIN verification with NIRA
- Photo capture
- Digital consent + signature logging
- Repeat borrower recognition

Loan Lifecycle

- Loan application submission
- Credit scoring & decisioning
- Loan disbursement via Mobile Money
- Repayment scheduling & auto-debit
- Default escalation workflow
- Credit rehabilitation logic

Device Control

- Device Owner provisioning
- Kiosk/Lock task activation
- Accessibility monitoring
- Boot persistence
- Root & tamper detection
- Factory Reset Protection monitoring

Integrations

- NIRA Identity API
- UCC IMEI & Telecom Behavior APIs
- CRB Credit Bureau APIs
- MTN MoMo APIs
- SMS Gateway
- Push Notifications

1.2 Non-Functional Requirements

Performance

- Scoring response < 2 seconds
- API latency < 500 ms for core endpoints
- Device lock trigger < 5 seconds online

Availability

- 99.5% backend uptime
- Offline lock enforcement capability
- Redundant SMS fallback channels

Scalability

- Horizontal scaling for scoring engine
- Stateless API services
- Queue-based async integrations

Security & Compliance

- AES-256 encryption at rest
- TLS 1.3 in transit
- Role-based admin access
- Full audit trails
- Explicit consent enforcement

Usability

- Low-literacy UI support
- One-hand usability
- Offline first flows

2. High-Level Architecture Components

Client Layer

- Android Loan App
- Kiosk/Lock Module
- Offline Token Manager

API Gateway Layer

- Authentication & JWT validation
- Rate limiting
- API key validation
- Logging

Core Services Layer

- Identity Service
- Loan Management Service (LMS)
- Scoring Engine Service
- Device Control Service
- Notification Service
- Integration Service

Intelligence Layer

- Feature Extraction Engine
- Behavioral Analytics Engine
- Risk Rule Engine

Data Layer

- Relational Database (PostgreSQL)
- NoSQL/Cache (Redis)
- Object Storage (S3 compatible)
- Audit/Event Store

External Systems

- NIRA
- UCC
- CRB
- MoMo

- SMS/USSD Providers

3. Data Flow Diagram (Logical Flow)

Registration Flow
User → Android App → API Gateway → Identity Service → NIRA → DB → OTP → User

Loan Application Flow
User → App → LMS → Scoring Engine → Integrations → Score → LMS → Offer → User

Default Enforcement Flow
Backend → Device Control Service → Push/SMS → Android Agent → Kiosk/Lock

Repayment Flow
User Wallet → MoMo → LMS → Scoring Update → Unlock Device

Offline Lock Flow
Backend sync → Offline Token → Boot Receiver → Kiosk Activation

4. Database Schema (Core Entities)

USERS {

uuid id PK

string phone_number

string nin

string first_name

string last_name

date date_of_birth

string gender

string selfie_url

string digital_signature_url

string residence_address

int residence_duration_months

string occupation

decimal self_reported_income

string registration_status

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

IDENTITY_VERIFICATIONS {

uuid id PK

uuid user_id FK

string nira_status

string crb_status

decimal crb_score

string crb_reference_number

json verification_payload

timestamp verified_at

uuid created_by

```
    uuid modified_by
    timestamp created_at
    timestamp last_modified_at
}
DEVICES {
    uuid id PK
    uuid user_id FK
    string imei
    string manufacturer
    string model
    string android_version
    date build_date
    boolean ucc_blacklist_status
    decimal resale_value_estimate
    string device_status
    uuid created_by
    uuid modified_by
    timestamp created_at
    timestamp last_modified_at
}
SIM_CARDS {
    uuid id PK
    uuid user_id FK
    uuid device_id FK
    string msisdn
    string network_provider
    date registration_date
    int sim_tenure_months
    string ucc_status
    uuid created_by
    uuid modified_by
```

timestamp created_at

timestamp last_modified_at

}

SCORES {

uuid id PK

uuid user_id FK

uuid loan_id FK

decimal identity_score

decimal device_score

decimal telecom_score

decimal financial_score

decimal total_score

string ml_model_version

json feature_snapshot

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

LOANS {

uuid id PK

uuid user_id FK

uuid device_id FK

uuid score_id FK

decimal principal_amount

decimal interest_rate

decimal total_due

string repayment_frequency

int term_days

string disbursement_reference

string status

date due_date

timestamp closed_at

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

REPAYMENTS {

uuid id PK

uuid loan_id FK

string momo_reference

decimal amount_paid

string payment_channel

string payment_status

timestamp paid_at

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

ENFORCEMENT_ACTIONS {

uuid id PK

uuid loan_id FK

uuid device_id FK

string action_type

string action_status

string external_reference

timestamp triggered_at

timestamp resolved_at

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

REHABILITATION_PROGRAMS {

uuid id PK

uuid user_id FK

uuid loan_id FK

int required_micro_payments

int completed_micro_payments

string status

timestamp started_at

timestamp completed_at

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

TELECOM_SNAPSHOTS {

uuid id PK

uuid user_id FK

uuid sim_id FK

string month

decimal airtime_topups_total

decimal momo_inflow_total

decimal momo_outflow_total

int transaction_count

decimal avg_wallet_balance

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

CONSENTS {

uuid id PK

uuid user_id FK

string consent_type

string ip_address

string user_agent

string signature_hash

timestamp signed_at

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

USER_SESSIONS {

uuid id PK

uuid user_id FK

string session_id

string ip_address

string user_agent

timestamp login_at

timestamp logout_at

int session_duration_seconds

json pages_visited

json activity_summary

string session_status

uuid created_by

uuid modified_by

timestamp created_at

timestamp last_modified_at

}

Relationships

USERS ||--o{ DEVICES : owns

USERS ||--o{ SIM_CARDS : registers

USERS ||--o{ LOANS : borrows

USERS ||--o{ SCORES : receives

USERS ||--o{ IDENTITY_VERIFICATIONS : verifies

USERS ||--o{ TELECOM_SNAPSHOTS : generates

USERS ||--o{ CONSENTS : signs

USERS ||--o{ USER_SESSIONS : logs

DEVICES ||--o{ SIM_CARDS : contains

DEVICES ||--o{ LOANS : collateral_for

DEVICES ||--o{ ENFORCEMENT_ACTIONS : affected_by

LOANS ||--o{ REPAYMENTS : has

LOANS ||--o{ ENFORCEMENT_ACTIONS : triggers

LOANS ||--o{ REHABILITATION_PROGRAMS : enters

SIM_CARDS ||--o{ TELECOM_SNAPSHOTS : produces

5. Smart Credit Scoring & Lock Control Logic

Credit Scoring Logic

1. Feature Extraction
2. Normalize Features
3. Apply Weighted Formula
4. Apply Rule Overrides
5. Generate Risk Band
6. Determine Loan Offer

Override Examples

- CRB blacklist → Immediate denial
- Rooted device → Reduce device score
- Multiple SIM swaps → Telecom penalty
- Perfect repayment history → Boost

Lock Control State Machine

States

- ACTIVE
- WARNING
- KIOSK
- SIM_BLOCK_REQUESTED
- IMEI_BLOCK_REQUESTED
- CLEARED

Transitions

- 1 day overdue → WARNING
- 3 days overdue → KIOSK
- 15 days overdue → SIM block request
- 30 days overdue → IMEI block
- Full payment → CLEARED

6. API Endpoint Outline

Authentication

- POST /auth/register
- POST /auth/verify-OTP
- POST /auth/refresh

Loans

- POST /loans/apply
- GET /loans/{id}
- POST /loans/repay
- GET /loans/history

Scoring

- POST /scoring/calculate
- GET /scoring/{user}

Device Control

- POST /device/lock
- POST /device/unlock
- POST /device/sync-status

Integrations

- /integrations/nira/verify
- /integrations/ucc/imei
- /integrations/crb/check
- /integrations/momo/disburse

Admin

- /admin/locks
- /admin/audit
- /admin/override

7. Security Considerations

Client Side

- Root detection
- App signature validation
- Encrypted Shared Preferences
- Obfuscation (R8/Pro-Guard)
- Tamper detection

Backend

- OAuth2 + JWT
- API key rotation
- Role-based access control
- IP whitelisting for regulators
- Full audit trails

Data Protection

- Encryption at rest
- Field-level encryption for NIN
- Pseudonymization for analytics(mask identity)
- Consent verification per request

Operational

- SIEM logging
- Rate limiting
- WAF + DDoS protection

8. Deployment Architecture

Cloud Layer

- Kubernetes Cluster
- Load Balancer
- API Gateway
- Microservices Pods
- Redis Cache
- PostgreSQL HA Cluster
- Object Storage
- Message Queue (RabbitMQ)

Regions

- Primary Region (Uganda/East Africa)
- Secondary DR Region
- Nightly backups
- Multi-AZ redundancy

CI/CD

- GitHub/GitLab pipelines
- Automated testing
- Blue-Green deployments

Monitoring

- Prometheus + Grafana
- ELK Stack
- Alerting (PagerDuty/SMS)
- Uptime probes